

BO2-03

Détection et protection des données personnelles

Rapport de réalisation - 8 octobre 2026

Branche de travail : ahmed-ikbel

1. Objectif du DSO

Identifier les données personnelles avant leur utilisation en aval, puis appliquer une politique de masquage ou de pseudonymisation. Le traitement doit protéger les informations ciblées tout en conservant les données métier utiles à l'analyse.

Le prototype réalisé utilise une copie de test entièrement synthétique. Il propose le choix des catégories à protéger et deux modes de transformation. La détection reste active pour les catégories décochées : leurs occurrences sont journalisées comme detected_only et restent lisibles.

2. Périmètre livré

Composant	Réalisation
Données	Copie dédiée de 500 lignes avec cinq colonnes supplémentaires ; dataset original inchangé.
Détection	Rôles de colonnes, expressions régulières et dictionnaire de noms fictifs.
Protection	Masquage typé ou pseudonymes HMAC avec liens conservés pendant la session.
Interface	Sélection des catégories, résultats, journal et exports CSV/JSON.
Validation	5 tests PII réussis, incluant le parcours Streamlit.

Fichiers concernés

- `data/pii_generator.py` : génération de la copie fictive.
- `governance/pii.py` : détection et transformation.
- `pages/3_BO2_PII.py` : interface Streamlit.
- `tests/test_pii.py` : tests de protection et de conservation.
- `governance_app.py` : navigation entre les DSO.

Données et détection ciblée

3. Conservation du schéma original

Les sept colonnes originales sont conservées dans la copie : age, income, spending_score, transaction_amount, num_transactions, true_anomaly et anomaly_type. Leurs valeurs ne sont pas modifiées par la protection PII sur le dataset de démonstration.

Colonne ajoutée	Contenu synthétique
full_name	Quatre noms fictifs, par exemple Amina Exemple.
email	Adresses de test utilisant le domaine example.com.
phone	Numéros fictifs de la plage +1-202-555-01xx.
national_id	Identifiants de démonstration DEMO-ID- suivis de six chiffres ; aucun véritable format national.
notes	Texte de contact contenant un nom, un email et un téléphone.

4. Comment les informations sont repérées

Colonnes déclarées personnelles : toute valeur textuelle non vide de full_name, email, phone ou national_id est considérée comme sensible selon le rôle déclaré. La valeur entière est protégée si sa catégorie est sélectionnée. Le rôle identifie la nature du champ ; il ne certifie pas la validité de son contenu.

Texte libre : les emails, les téléphones pris en charge et les identifiants DEMO-ID sont repérés par expressions régulières. Les noms fictifs sont repérés par un dictionnaire. Seuls les fragments correspondants sont remplacés ; le reste de la phrase reste lisible.

Le moteur recherche également ces motifs dans les autres colonnes textuelles. Sur les données actuelles, les sept colonnes initiales ne contiennent pas de tels motifs : elles restent intactes. Une valeur métier n'est pas réputée non confidentielle simplement parce qu'elle n'est pas transformée par ce prototype.

5. Sélection des catégories

Noms, emails, téléphones et identifiants personnels sont sélectionnés par défaut. L'utilisateur peut adapter le périmètre. Si une catégorie est décochée, l'interface indique que la protection est partielle et que ses valeurs resteront présentes dans l'export. Aucune catégorie inconnue n'est acceptée par le moteur.

Masquage et pseudonymisation

6. Deux politiques de traitement

Mode	Effet
Masquage	Remplacement par une étiquette de type : [MASKED_EMAIL], [MASKED_PERSON], etc. Les valeurs distinctes d'un même type ne sont plus distinguables.
Pseudonymisation	Remplacement par un jeton propre à la valeur et au type. La même valeur normalisée reçoit le même jeton dans la session, y compris dans les notes.

Exemple de masquage limité aux emails :

Avant : Commande 42 : x@example.com ; Amina Exemple.

Après : Commande 42 : [MASKED_EMAIL] ; Amina Exemple.

Le numéro de commande et le nom non sélectionné restent lisibles.

7. Construction des pseudonymes

Le moteur utilise HMAC-SHA256 avec une clé aléatoire de 32 octets créée par session Streamlit. Le jeton contient le type et les 32 premiers caractères hexadécimaux du résultat HMAC, soit 128 bits. Il n'est pas calculé avec un simple hachage public sans secret.

Les valeurs sont normalisées avant le calcul : suppression des espaces périphériques, regroupement des espaces et conversion de casse ; pour les téléphones, seuls les chiffres sont conservés. Les liens dépendent donc de cette convention de normalisation et du type d'entité.

La clé n'est ni affichée ni exportée. Aucune table de correspondance réversible n'est conservée. Une nouvelle session utilise une nouvelle clé : les pseudonymes ne sont pas stables entre sessions. Une gestion de clés durable serait nécessaire pour conserver des liens sur plusieurs exécutions.

8. Journal et responsabilités

Chaque occurrence produit une entrée avec la position de ligne, la colonne, le type d'entité, la méthode de détection et l'action. Le journal ne contient pas la valeur personnelle source. Le manifeste porte la politique pii-demo version 1.1.0, son périmètre de démonstration, les catégories sélectionnées, le mode et les limites.

DQ correspond à la détection et **ETL** aux transformations. Il s'agit de fonctions locales. L'application présente par défaut les résultats protégés, mais ne fournit pas encore une authentification, des droits par rôle ou une protection imposée à tous les agents aval.

Utilisation, résultats et limites

9. Parcours de démonstration

1. Lancer `.venv\Scripts\python -m streamlit run governance_app.py`.
2. Ouvrir **BO2-03 · Données personnelles**.
3. Choisir masquage ou pseudonymisation et les catégories concernées.
4. Cliquer sur **Détecter et protéger**.
5. Examiner les données métier conservées, le résultat et le journal.
6. Exporter le CSV selon la sélection et le journal JSON.

L'affichage des données fictives avant protection exige de cocher une option, désactivée par défaut. Changer de mode ou de catégories invalide le résultat précédent. Les exports ne transmettent rien automatiquement aux autres agents.

10. Résultats et tests

Avec les quatre catégories sélectionnées, les 500 lignes produisent **3 500 occurrences protégées** : quatre champs personnels et trois fragments dans les notes par ligne. Le périmètre couvre cinq colonnes. Ce total décrit la démonstration ; il ne mesure pas la performance sur des données réelles.

Test	Vérification
Conservation	Les sept colonnes originales et le DataFrame source restent inchangés.
Protection et liens	Absence des valeurs sources testées dans la sortie et le journal ; liens identiques et changement de clé effectif.
Valeurs particulières	Valeurs absentes conservées, noms hors dictionnaire protégés dans la colonne déclarée, plusieurs emails détectés.
Périmètre ciblé	Seules les catégories sélectionnées sont transformées ; données métier et fragments non ciblés conservés.
Interface	Affichage brut désactivé, exécution et changement de mode sans résultat obsolète.

11. Limites explicites

Pas de NER général ni de modèle Microsoft Presidio : les noms libres hors dictionnaire peuvent être manqués. Les formats de téléphone et d'identifiant couverts sont limités. Il n'existe pas de validation métier de production, de stockage sécurisé durable des clés, de contrôle d'accès multiutilisateur ou de garantie d'absence de PII résiduelle.

La pseudonymisation n'est pas l'anonymisation : les attributs restants peuvent permettre une réidentification. Les suites sont l'extension des détecteurs, une évaluation des faux positifs et faux négatifs, puis l'authentification et l'application obligatoire de la protection avant les usages aval.